# Digital Forensics in Incident Response - **DFIR**

Dr Olga Angelopoulou

ROYAL HOLLOWAY UNIVERSITY OF LONDON

# Learning Outcomes

- Develop a critical understanding on the various methodologies involved in incident response (IR) and their phases
- Identify the role of digital forensics and the forensics examiner in IR

# DFIR

1. Digital Forensics & Incident Response
2. Integration of digital forensics and incident response
3. Focuses on:
   i. Detecting security incidents
   ii. Containing and eradicating threats
   iii. Investigating what happened and why
4. Used in:
   i. Cyber attacks
   ii. Insider incidents
   iii. Data breaches
   iv. Malware infections

# DFIR vs Traditional Digital Forensics

ROYAL HOLLOWAY UNIVERSITY OF LONDON

## Digital Forensics

- Often retrospective
- Evidence analysed after an incident
- Strong emphasis on preservation and reconstruction

## DFIR

- Conducted during live or ongoing incidents
- Time-critical decision making
- Evidence collection may be selective or partial
- Strong operational focus

# DFIR Main Evidence Sources

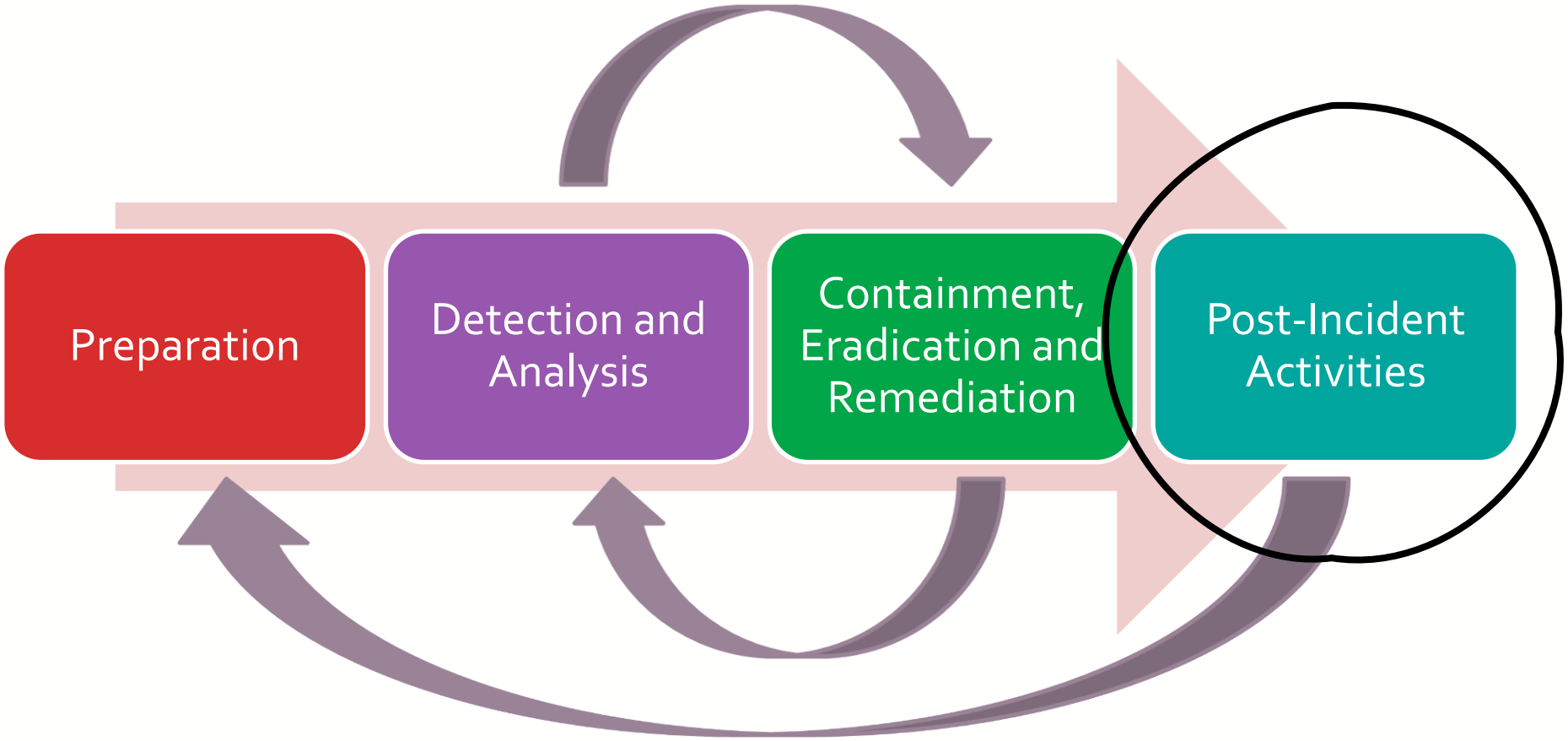
ROYAL HOLLOWAY UNIVERSITY OF LONDON

- Memory and live system data
- Logs and telemetry
- Network traffic
- Endpoint artefacts
- Cloud and third-party logs

# IR Methodologies

ROYAL HOLLOWAY UNIVERSITY OF LONDON

# Incident Response Lifecycle

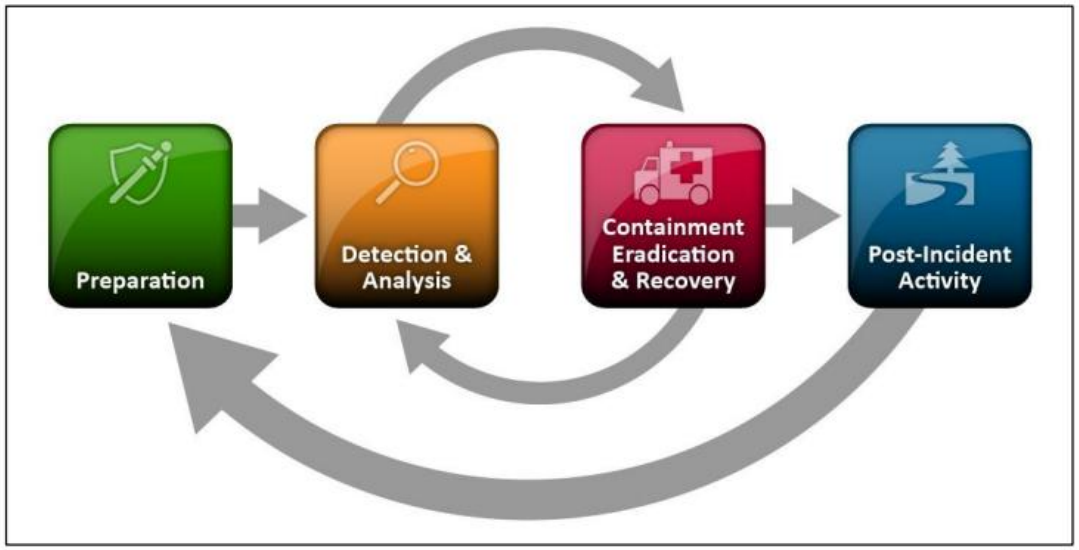


# NIST - National Institute of Standards & Technology (US)

Four step process:

1. Preparation
2. Detection and Analysis
3. Containment, Eradication and Recovery
4. Post-Incident Activity

<u>Computer Security Incident Handling Guide</u>



# SANS - SysAdmin, Audit, Network and Security

Six step process:

1. Preparation
2. Identification
3. Containment
4. Eradication
5. Recovery
6. Lessons Learned

Incident Handler's Handbook

*Source: SANS SEC 504 (Incident Handling), Book 1, Page 13*

# Adding Forensics to Incident Response

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- Identify forensic resources the organization can use in case of an incident
- Identify an outside party that can respond to incidents with forensically trained personnel
- Weave forensic methodology into organization's incident response policy
- Provide appropriate training to staff for preserving evidence
  - Preservation of evidence **MUST** be considered as part of the process to avoid destroying evidence during the response phase, e.g. rebuilding a system
- Plan, plan, and plan again. Then **test**!

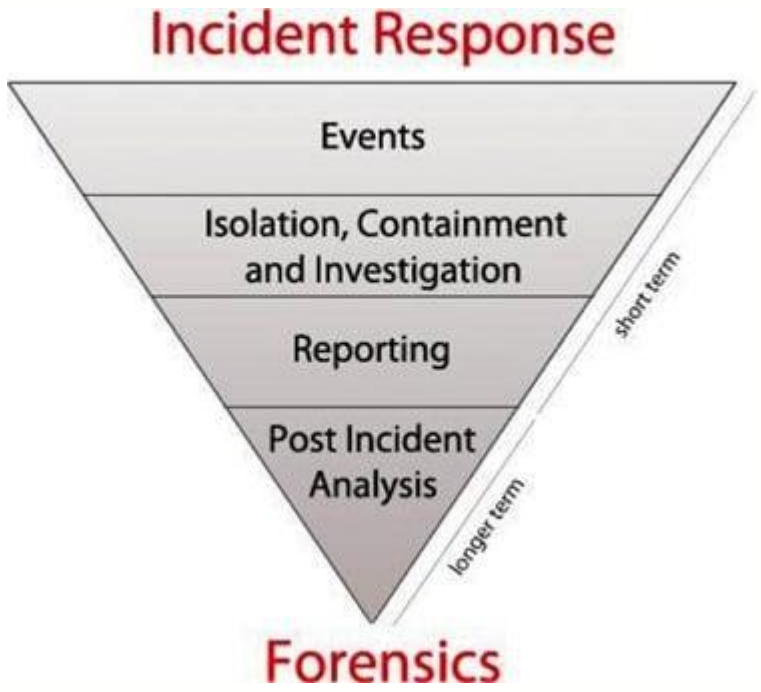
# The role of DF in IR

## Post-Incident Forensics

1. Identify what actually happened and get to the root cause and be able to calculate impact
2. Potentially create evidence that is admissible in court

## IOC Discovery

1. Post incident, it is good practice to use DF to determine what IOC can be derived from the evidence to add to the Threat Hunting portfolio.
2. You can pro-actively use DF techniques as an analysis tool to determine what the impacts of a given attack or compromise look like




https://resources.infosecinstitute.com/topics/digital-forensics/

## Classifying an Incident

- Develop a classification system
  - Varies by industry type
  - Should meet legal and regulatory obligations
- Common approach is to use categories that assess threat level
  - Malicious code
  - Denial of Service
  - Unauthorised access
  - Inappropriate usage
- Major vs. minor
  - Major incidents are significant
  - Determination based on risk to organisation

## Classifying Breach by Attack Vector

- Attack Vectors
  - SQL injection
  - Improperly segmented network environment
  - Malicious code or malware
  - Insecure remote access
  - Insecure wireless

# Frameworks for IR

ROYAL HOLLOWAY UNIVERSITY OF LONDON

## ISO 27001

International standard for an information security management system

Annex A.16.1 : management of information security incidents, events and weaknesses

## ISO 22301

International standard for a business continuity management system

- helps organisations identify and prioritise threats
- allows them to implementan effective business continuity management system
- respond to and recover from incidents with the least disruption to business.

## PCI DSS

Payment Card Industry Data Security Standard

- requirement for incident response
- requirement for Payment Card Industry Forensic Investigator (PFI)

# Preserving Evidence

1. An event is any observable occurrence within a system or network
   i. Includes network activity, such as when a user accesses files on a server or when a firewall blocks network traffic
2. Adverse events have negative results or negative consequences
   i. Example: An attack on a system
3. Recovery often performed at the expense of preserving forensic evidence
4. Failure to preserve forensic information:
   i. Prevents IT team from effectively evaluating cause of incident
   ii. Makes it difficult to modify company policies and procedures to reduce risk
5. Forensic data is key to preventing future incidents

# IR within GDPR and NIS Directive

Aim to strengthen and unify data protection for individuals within the EU and address export of personal data outside the EU.

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- Data breach notification is mandatory
  - organisations have approx. **72 hours** to notify the relevant data protection authority when a breach has occurred.
- Gathering customer data needs to be in accordance with the procedures specified in the GDPR
  - specify how personal data are permanently deleted from all data repositories upon request, "the right to be forgotten".
  - upon request businesses will need provide electronically any data being held for a particular individual when asked, in a timely manner and in a commonly used format.

# Post-Incident Forensics

- The role of forensics in incident response serves two main purposes:

  1. Figure out what *actually* happened and get to the root cause and be able to calculate impact
     - Complements live incident response
     - Conducted after containment and recovery
     - Reconstructs a reliable timeline of events
     - Identify root cause and attacker actions
     - Assess scope and impact

  2. Preserve evidence for legal, regulatory, or disciplinary use

# Where in the methodology does it fit ?

- Usually in both the Respond and Follow-Up phases.

- You may need to do forensic work to determine what is happening at a given time and use this to refine your response.

- Preservation of evidence is important, and needs to be
  - considered as part of the process otherwise there is a risk that it may be destroyed during the response phase. e.g. rebuilding a system

# Challenges in Post-Incident Forensics

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- Investigators often work with what remains, not with what once existed.
  - Evidence overwritten during recovery
  - Logs rotated or cleared
  - System rebuilds remove artefacts
  - Reliance on secondary evidence (backups, logs, memory dumps)

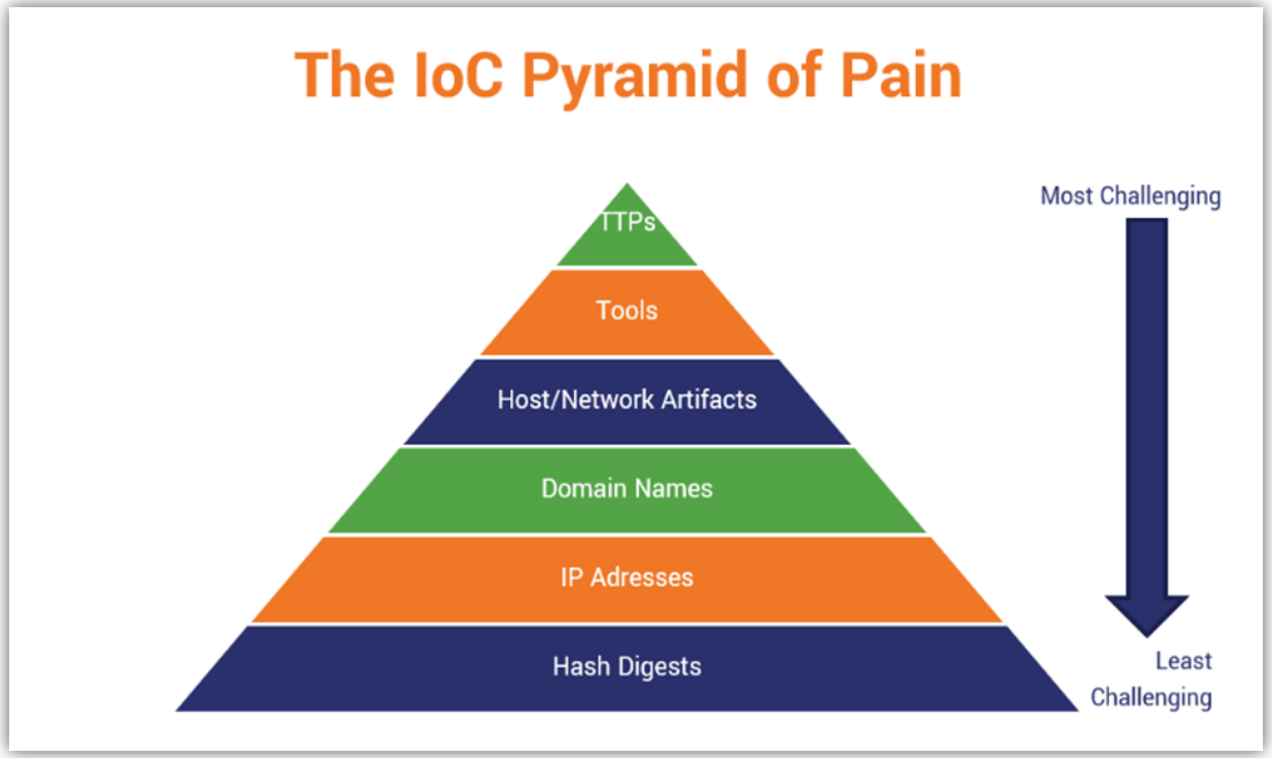
# Threat Hunting and DF ?

## IOC Discovery – Indicators Of Compromise

- Post incident, it is good practice to use DF to determine what IOC can be derived from the evidence to add to the Threat Hunting portfolio.

- You can pro-actively use DF techniques as an analysis tool to determine what the impacts of a given attack or compromise look like.

- Network-Based
- Host-Based
- User and Access Behavioral
- System/Log Anomalies




**Source**: https://www.thesslstore.com/blog/indicators-of-compromise-cybersecuritys-digital-breadcrumbs/

# Live Forensics Objectives

ROYAL HOLLOWAY UNIVERSITY OF LONDON

# Introduction

- Assistance with static analysis
- Obtain passwords, key material, unencrypted data
- Reconstruct session and application information
- Identify network traffic and applications

In other cases, taking down a system is undesirable:

- Forensic investigation may need to be conducted clandestinely
- Mission-critical systems may not be shut down, or downtime must be kept to a minimum

# Live Forensics Benefits

- Most applications (and host systems) are not designed to minimize exposure of sensitive data in volatile memory
- Passwords, cryptographic material, but also application data is typically retained
- Even when memory is released, it is typically not overwritten for performance reasons
  - Particularly on relatively quiescent systems with large amounts of RAM, this can result in retention of data long after a process has finished
  - If such memory is re-used without being zeroed out, other processes may also leak this information, e.g., in crash dumps

# Live Imaging Techniques

- Most straightforward mechanisms for obtaining live memory require some level of operating system support
- Physical memory access, dumping of memory content
- This typically implies synchronization or locking, but may not always be feasible or desirable
- Two key problems are (almost) unavoidable in this context:
  - **Volatility:** Even if the target system is (largely) frozen during a snapshot, some background volatility inevitably remains
  - **Artefacts:** The very fact that observations are conducted will result in artefacts

# Live DFIR vs Post-Incident Forensics

| Aspect | Live DFIR | Post-Incident Forensics |
|---|---|---|
| **Primary goal** | Contain and stop the incident | Understand and explain the incident |
| **Timing** | During active compromise | After containment and recovery |
| **Evidence state** | Volatile, changing | Static, incomplete |
| **Priority** | Speed and impact reduction | Accuracy and defensibility |
| **System state** | Often live and operational | Often rebuilt or restored |
| **Analysis focus** | Indicators, attacker presence | Timeline, root cause, scope |
| **Risk** | Evidence contamination | Evidence loss |
| **Output** | Alerts, containment actions | Reports, lessons learned, legal input |

# Live Forensics Tools

ROYAL HOLLOWAY UNIVERSITY OF LONDON

# Live Forensic Tool Examples

Tools such as the **Sysinternals** set originally developed by Mark Russinovich provide access to key (volatile) kernel data structures

- **Networking:** Various network interface activity monitors
- **Security:** Access rights checks, local and remote shares and access to these
- **Processes:** Real-time DLL, thread, and process activity monitoring and dependencies among components
- **System Information:** Review Active Directory structures, memory mapping, file handles, **live kernel debugging**
- **File and Disk:** File system activity

Also contains a tool (Disk2VHD) to capture an image and convert it to a virtual drive

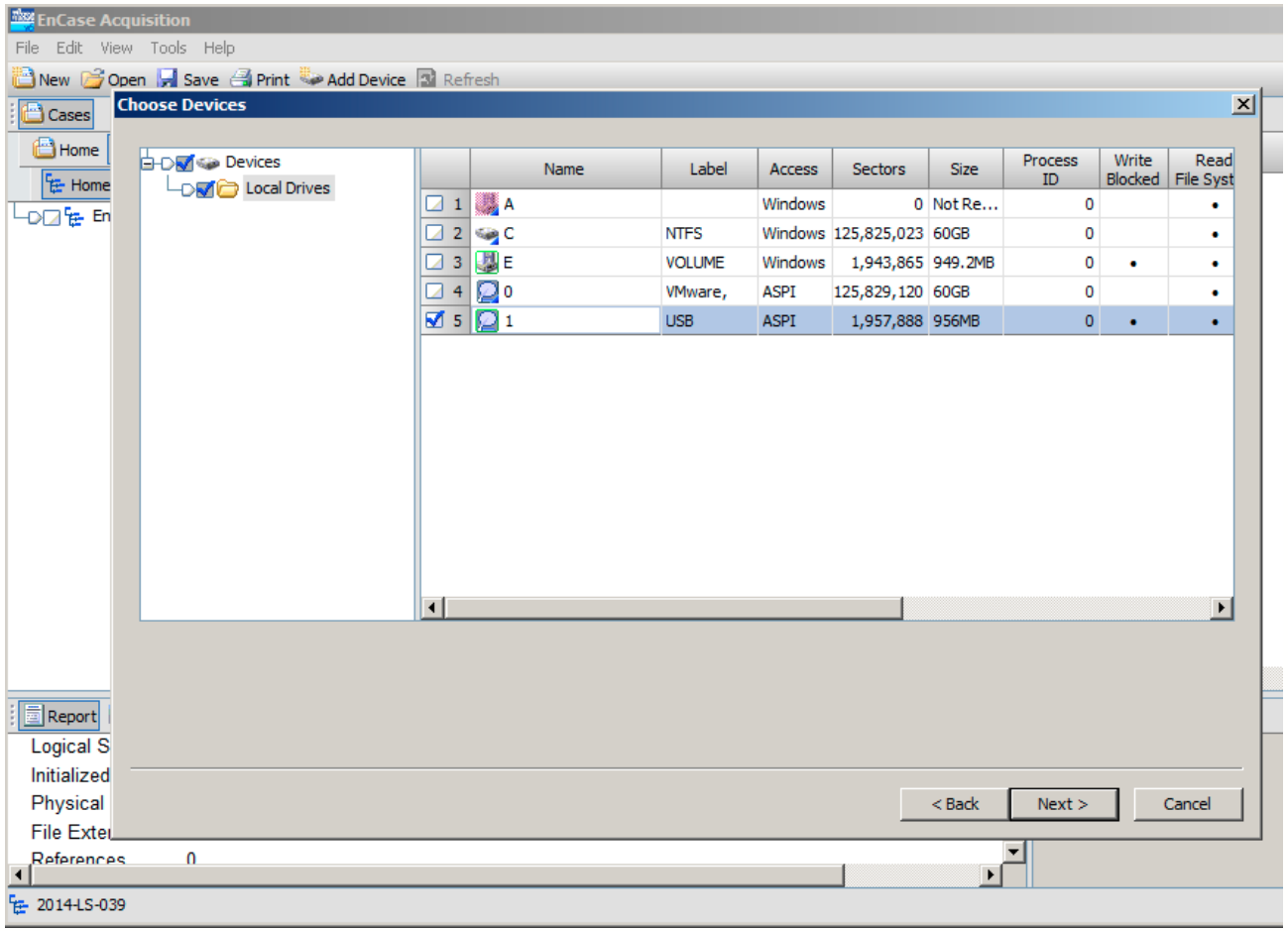
- The **Sysmon** tool (introduced 2014) allows logging and tracking of process activity

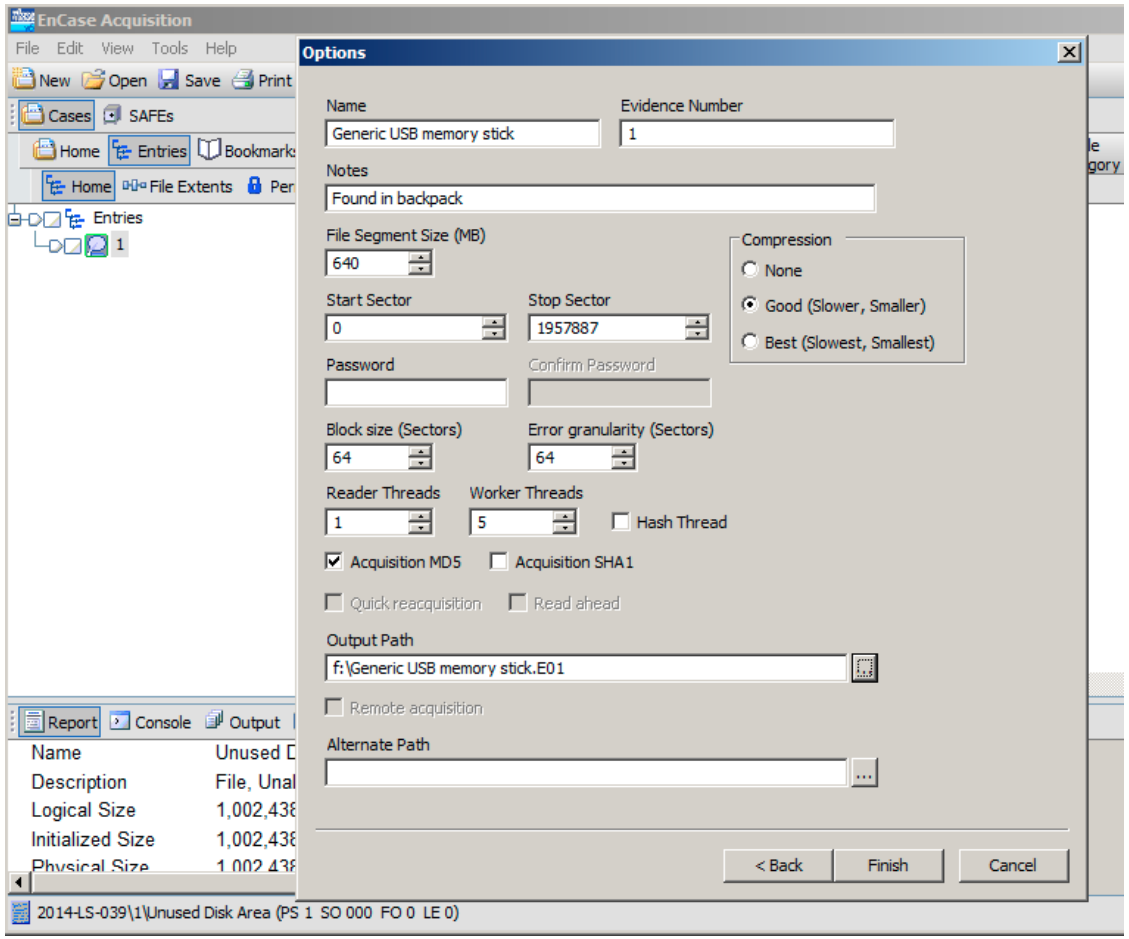
# Live Forensic Imaging Tool Examples

Examples include:

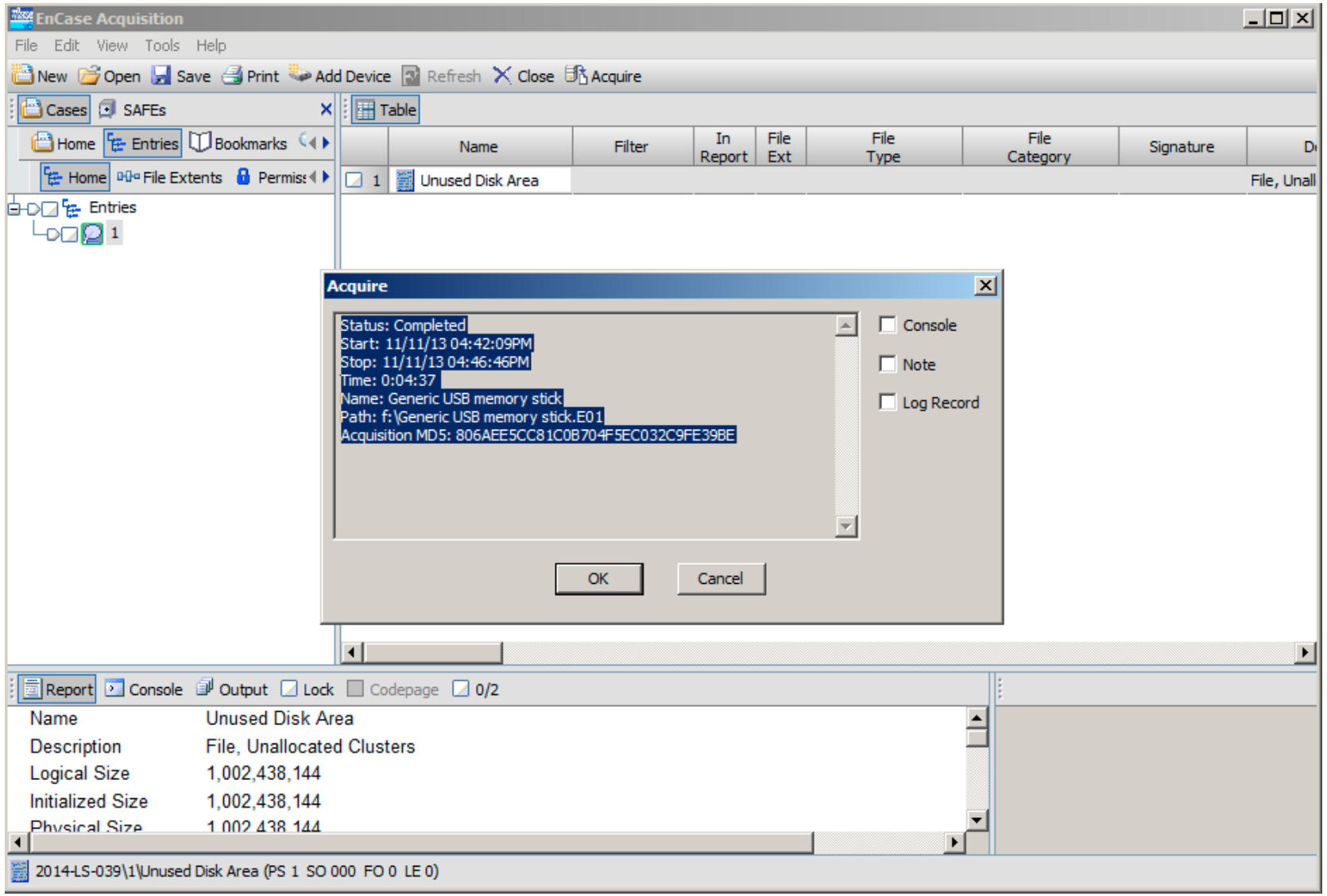
- **ProDiscover:** Triage / Pro
- **EnCase:** OpenTex Forensic / Endpoint Forensics and Response (aka EnCase)
- **FTK:** Access Data' Forensic Toolkit also memory capture using an agent-based architecture
  - Live disk and memory acquisition
  - Supports logical and physical imaging
  - Widely used in law enforcement and industry
- **dd (Unix/Linux)**
  - Low-level disk imaging utility
  - Powerful but requires careful handling and documentation

# Example: EnCase Views

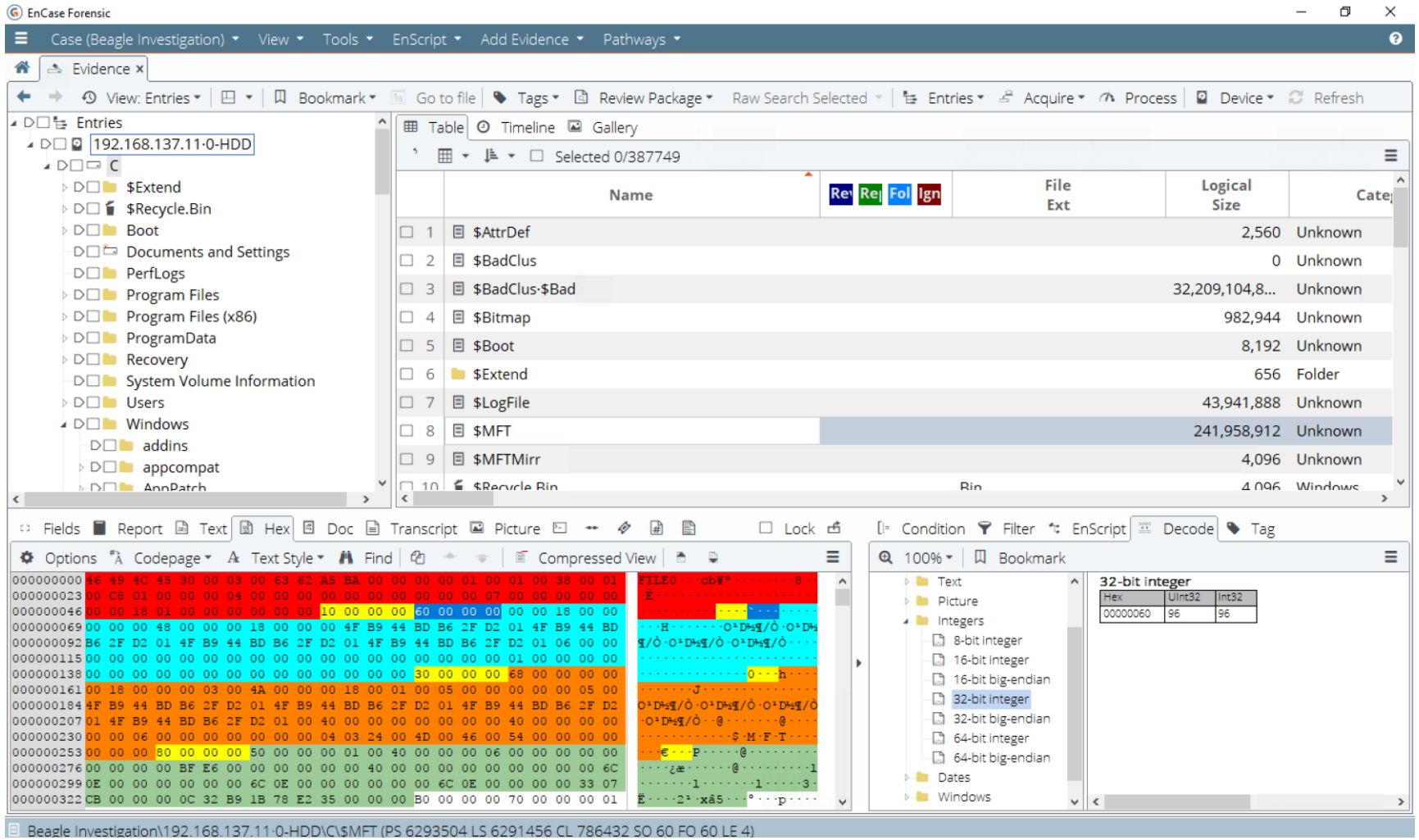


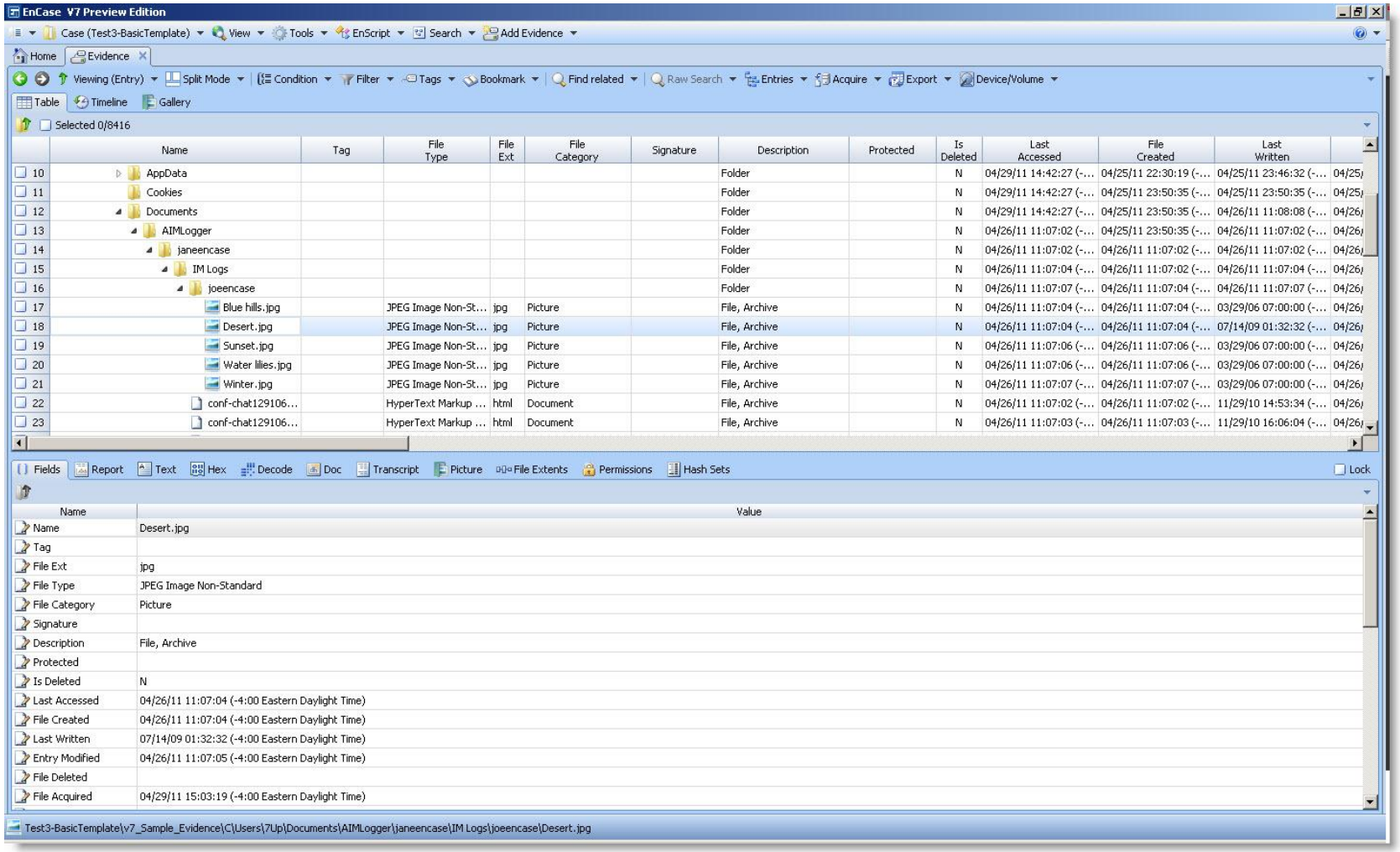
# Example: EnCase Views



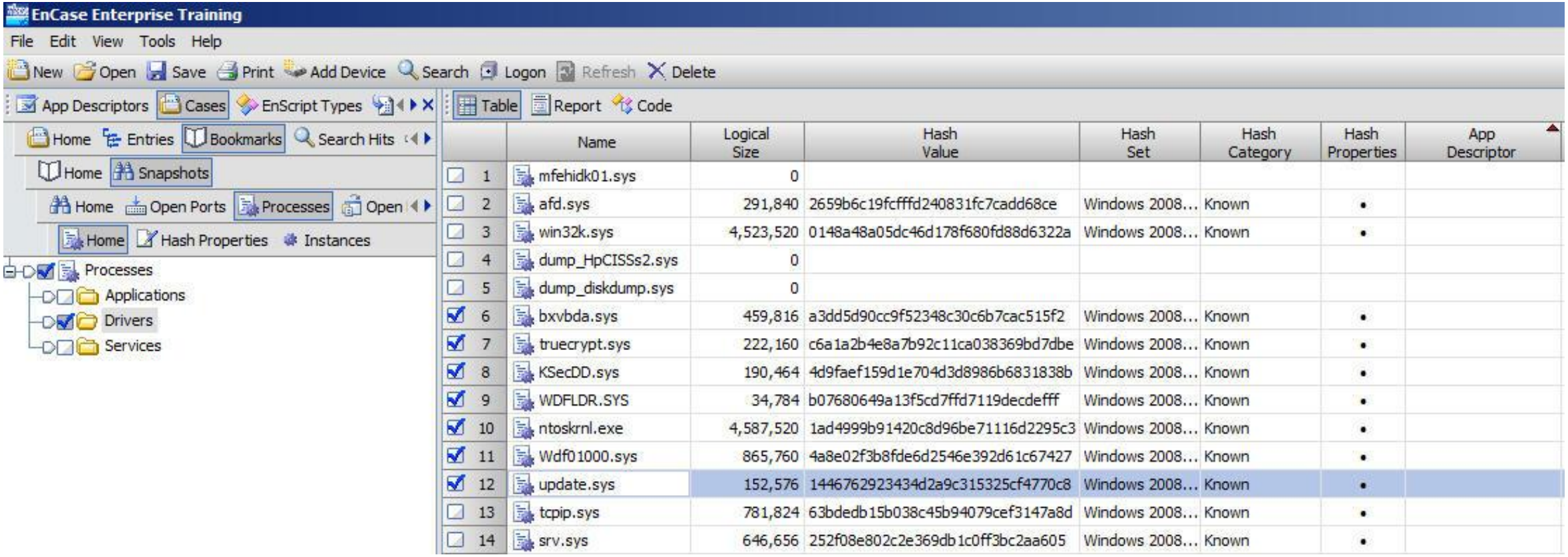
# Example: EnCase EI 8 / EE 7 Views



# Example: EnCase EI 8 / EE 7 Views

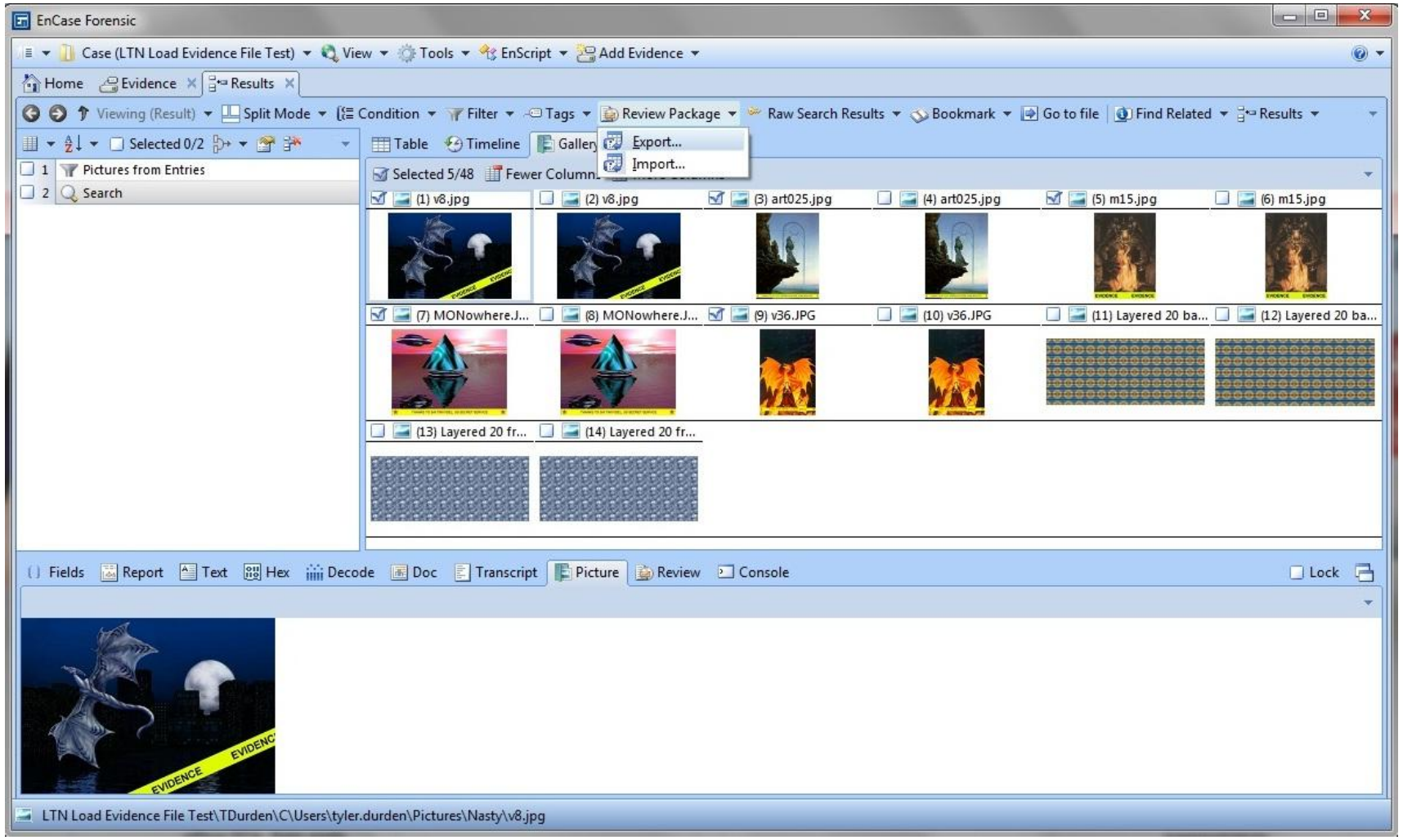


# Example: EnCase EI 8 / EE 7 Views




| | Name | Logical Size | Hash Value | Hash Set | Hash Category | Hash Properties | App Descriptor |
|---|---|---|---|---|---|---|---|
| 1 | mfehidk01.sys | 0 | | | | | |
| 2 | afd.sys | 291,840 | 2659b6c19fcfffd240831fc7cadd68ce | Windows 2008... | Known | • | |
| 3 | win32k.sys | 4,523,520 | 0148a48a05dc46d178f680fd88d6322a | Windows 2008... | Known | • | |
| 4 | dump_HpCISSs2.sys | 0 | | | | | |
| 5 | dump_diskdump.sys | 0 | | | | | |
| 6 | bxvbda.sys | 459,816 | a3dd5d90cc9f52348c30c6b7cac515f2 | Windows 2008... | Known | • | |
| 7 | truecrypt.sys | 222,160 | c6a1a2b4e8a7b92c11ca038369bd7dbe | Windows 2008... | Known | • | |
| 8 | KSecDD.sys | 190,464 | 4d9faef159d1e704d3d8986b6831838b | Windows 2008... | Known | • | |
| 9 | WDFLDR.SYS | 34,784 | b07680649a13f5cd7ffd7119decdefff | Windows 2008... | Known | • | |
| 10 | ntoskrnl.exe | 4,587,520 | 1ad4999b91420c8d96be71116d2295c3 | Windows 2008... | Known | • | |
| 11 | Wdf01000.sys | 865,760 | 4a8e02f3b8fde6d2546e392d61c67427 | Windows 2008... | Known | • | |
| 12 | update.sys | 152,576 | 1446762923434d2a9c315325cf4770c8 | Windows 2008... | Known | • | |
| 13 | tcpip.sys | 781,824 | 63bdedb15b038c45b94079cef3147a8d | Windows 2008... | Known | • | |
| 14 | srv.sys | 646,656 | 252f08e802c2e369db1c0ff3bc2aa605 | Windows 2008... | Known | • | |

# Example: EnCase EI 8 / EE 7 Views



# Memory and Live Forensics

ROYAL HOLLOWAY UNIVERSITY OF LONDON

# Why is this important?

1. Running processes
2. Active network connections - Network artefacts
3. DLLs and loaded modules
4. Encryption keys - Decrypted content
5. In-memory malware - Injected code
6. Command history
7. Clipboard content

# Basic Principles (1/2)

Memory forensics can be considered to be divided into two broad categories:

- **In-System Acquisition:** Software-based acquisition methods of volatile information including RAM and other system state may rely on processes in the target of observation; full-on emulation may be an exception, but this is an extremely specialized case and not realistic as it requires resources several orders of magnitude larger than of the target system
- **External Acquisition:** Hardware-based acquisition methods can be designed in a way that the target is not altered (at the level relevant for digital forensics)

Analysis will typically occur on a memory image to preserve reproducibility unless dynamic behavior analysis is needed

# Basic Principles (2/2)

In-system (live) acquisition limits: **Any in-system acquisition will alter the state of the system it intended to be acquired**

Fundamental limits:

- The exact system state that would exist without the intervention (or mere presence) of the acquisition system cannot be known a priori
- The presence of **counter-forensic** components may prevent accurate acquisition, even when using tamper-resistant components

These considerations apply for the basic case of a memory snapshot but are more problematic in actual **live** forensics where forensic examination interacts with the examination subject

# In-System Acquisition – Limitations

For in-system acquisition some of the key problems arise from the fact that it is not possible to **freeze** the target system completely:

- Acquiring a memory snapshot takes time, even if one were to stop all concurrent processing units bar one, and not all system state can be captured reliably
- As a result, software-based snapshots are normally not completely **atomic**, i.e., not all causality may be correctly represented in a memory image

Achievable atomicity hence degrades as the amount of memory to be captured increases, which also has an effect on the **integrity** of the memory image, i.e., if data has been altered after the nominal snapshot time

# Memory Image Analysis Techniques (1/2)

Basic techniques for live forensics do not differ fundamentally based on operating system

- Knowledge of kernel structures and process life-cycles is essential

String searches (**carving**): Extraction of strings from live memory or images may at times suffice

- Relevant data may be encoded in different ways (e.g., ASCII, UNICODE, potentially using homonym encoding)
- Signature matching, based on (hash) fingerprinting to identify in-memory structures and objects

Further analysis requires understanding of kernel structures

- For applications the derivation of page frame structures will often provide valuable information of running processes at the time of a snapshot

# Memory Image Analysis Techniques (2/2)



Page (swap) space may not only hold usable payload (process) information, but also structural information

- Page directory and table entries can themselves be paged and are highly useful in reconstructing physical memory dumps

Even **direct kernel object manipulation** (DKOM) commonly used by malware (e.g., rootkits) is not perfect and leaves artefacts:

- Subversion will typically still leave **some** traces or at least inconsistent data structures
- Example: Processes that do not appear in a process list must still be runnable to be useful, or have traces in the memory management subsystem
- A snapshot may, e.g., also uncover any inconsistencies between on-disk kernel image or known semantics and (live) image

# Memory Imaging and Analysis Tools

ROYAL HOLLOWAY UNIVERSITY OF LONDON

**Memory Acquisition**

- DumpIt
  - Simple, lightweight memory capture tool
  - Designed for rapid deployment during incidents
- FTK Imager
- Opentext Endpoint Investigator
- Belkasoft RAM Capturer
  - Memory acquisition with driver-based access
  - Often used in Windows environments

**Memory Analysis**

- Volatility Framework/ Volatility 3
  - Standard for memory forensics
- Rekall
  - Alternative memory analysis framework
  - Emphasis on speed and automation
- Magnet AXIOM
  - GUI-driven memory analysis
  - Integrates RAM artefacts with disk and mobile data
- Memoryze (Windows)
  - Acquisition and analysis

# GPU Memory

- GPUs contain dedicated memory (VRAM) separate from system RAM.
- Data processed by GPU applications may never appear in traditional RAM captures.
- Increasing use in:
  - AI and machine learning workloads
  - Cryptocurrency mining
  - Password cracking and brute-force attacks
  - Malware using GPU acceleration

# Key Components of GPU Architecture

- GPU cores – parallel execution units for computation
- VRAM – high-bandwidth memory storing textures, buffers, and compute data
- Driver layer – interface between OS and GPU hardware
- Compute frameworks – e.g., CUDA, OpenCL, DirectCompute

**Forensic Implication**

- Traditional memory forensics that captures system RAM alone may miss GPU-resident artefacts, meaning important evidence could remain outside the investigator's view.

# Forensic Challenges and Opportunities in GPU Analysis

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- Potential Artefacts in GPU Memory
  - Rendered images and frame buffers
  - Machine learning datasets or model fragments
  - Passwords or cryptographic material used in GPU-based cracking tools
  - Malware code executed through GPU compute kernels
  - Data buffers transferred between CPU and GPU
- Challenges for Investigators
  - Limited acquisition tools: Most forensic tools target CPU memory only.
  - Volatility: VRAM is cleared quickly when processes terminate or the GPU resets.
  - Proprietary architectures: Vendors like NVIDIA, AMD, and Intel use different driver structures.
  - Driver mediation: The operating system typically interacts with GPUs through drivers, making low-level access difficult.

# Emerging Research Directions

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- GPU memory acquisition techniques
- Detection of GPU-assisted malware
- Reconstruction of compute workloads from VRAM artefacts
- Analysis of driver-level logs and API calls

# GPU-Based Malware and Forensic Detection

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- Attackers increasingly exploit GPUs because they offer high parallel processing power and operate somewhat outside the traditional monitoring focus of security tools.

- Common motivations include:
  - High-speed computation (password cracking, cryptomining)
  - Offloading malicious workloads from the CPU
  - Reduced visibility to conventional monitoring tools
  - Potential stealth by executing code in GPU compute kernels
  - Malware could load malicious kernels into GPU memory, execute them there, and avoid detection by traditional host-based security tools.
- Forensic Indicators
  - Unusual GPU utilisation without expected workloads
  - Suspicious GPU compute processes (CUDA/OpenCL)
  - Abnormal driver API calls to GPU memory buffers
  - Unexpected GPU memory allocations
  - Evidence of GPU-accelerated tools (e.g., password cracking frameworks)

| Activity | Description |
|---|---|
| **Cryptomining malware** | Uses GPU cores to mine cryptocurrency efficiently |
| **Password cracking** | Tools like GPU-accelerated brute force attacks |
| **GPU rootkits (research prototypes)** | Malware executing entirely in GPU memory |
| **Data exfiltration experiments** | Covert channels between GPU and CPU memory |

# Detection and Investigation Approaches

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- No single approach (yet)
- New execution environment

- Monitoring GPU utilisation via system tools (e.g., vendor utilities)
- Analysing driver-level logs and API activity
- Examining processes interacting with GPU compute frameworks
- Correlating CPU, RAM, and GPU activity timelines

# Volatility Example

ROYAL HOLLOWAY UNIVERSITY OF LONDON

# Scenario

- A staff workstation is suspected of executing a malicious document received via email. You are provided with a Windows 10 memory image. Determine whether malicious activity occurred.

- *Memory image: Win10.mem*
- *Memory dump: FTK Imager*
- *Analysis Tool: Volatility 3*

# Step 1: Identify the OS

```
vol.py -f Win10.mem windows.info
```

**Output:**

```
Variable                        Value

--------------------------- -------------------------

Kernel Base                     0xf8025c000000

DTB                             0x1aa000

Is64Bit                         True

Major/Minor                     10.0

Build                           19041

System Time                     2025-02-17 14:22:31 UTC
```

# Step 2: Process Listing

**Pslist = Process listing / Pstree = Process tree**

```
vol.py -f Win10.mem windows.pslist
```

**Output**

| PID | PPID | ImageFileName | CreateTime |
|---|---|---|---|
| 4 | 0 | System | 2025-02-17 13:59:10 |
| 580 | 4 | smss.exe | 2025-02-17 13:59:12 |
| 724 | 580 | csrss.exe | 2025-02-17 13:59:15 |
| 820 | 580 | wininit.exe | 2025-02-17 13:59:18 |
| 2332 | 1820 | OUTLOOK.EXE | 2025-02-17 14:10:03 |
| 3448 | 2332 | WINWORD.EXE | 2025-02-17 14:11:10 |
| 4120 | 3448 | powershell.exe | 2025-02-17 14:11:25 |

```
python3 vol.py -f Win10.mem windows.pstree
```

```
OUTLOOK.EXE (2332)
└──── WINWORD.EXE (3448)
      └──── powershell.exe (4120)
```

# Step 3: Network Connections

**Netscan**

```
python3 vol.py -f Win10.mem windows.netscan
```

Output

```
PID    LocalAddr          ForeignAddr          State
4120   192.168.56.101     192.168.56.10:80     ESTABLISHED
```

# Step 4: Memory Injection

## Malfind – Find malware

```
python3 vol.py -f Win10.mem windows.malfind
```

## Output

```
PID    Process          Start              End                Protection
-----  ---------------  -----------------  -----------------  -------------------------
4120   powershell.exe   0x000001f3c2a00000 0x000001f3c2a1f000 PAGE_EXECUTE_READWRITE

Vad Tag: VadS
CommitCharge: 32
PrivateMemory: True
FileObject: None
Protection: PAGE_EXECUTE_READWRITE
Hex Dump:
0x000001f3c2a00000  4d 5a 90 00 03 00 00 00 04 00 00 00 ff ff 00 00  MZ..............
0x000001f3c2a00010  b8 00 00 00 00 00 00 00 40 00 00 00 00 00 00 00  ........@.......
0x000001f3c2a00020  00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  ................
0x000001f3c2a00030  0e 1f ba 0e 00 b4 09 cd 21 b8 01 4c cd 21 54 68  ........!..L.!Th
0x000001f3c2a00040  69 73 20 70 72 6f 67 72 61 6d 20 63 61 6e 6e 6f  is program canno
0x000001f3c2a00050  74 20 62 65 20 72 75 6e 20 69 6e 20 44 4f 53 20  t be run in DOS 
0x000001f3c2a00060  6d 6f 64 65 2e 0d 0d 0a 24 00 00 00 00 00 00 00  mode....$.......
0x000001f3c2a00070  50 45 00 00 64 86 06 00 00 00 00 00 00 00 00 00  PE..d...........
```

# Summary

ROYAL HOLLOWAY UNIVERSITY OF LONDON

# Summary

- If you are responding on an incident, take notes of everything
- Preparation is key in incident response
- It is very important to have a concrete plan in place about what happens during an incident

# Questions?

ROYAL HOLLOWAY UNIVERSITY OF LONDON

# References


Lillard V.T., 2010, Digital Forensics for Network, Internet, and Cloud Computing: A Forensic Evidence Guide for Moving Targets and Data, Elsevier Inc., ISBN 978-1-59749-537-0

Prosise C. and Mandia K., 2003, Incident Response and Computer Forensics, The McGraw-Hill Companies, ISBN: 0-07-222696-X

Schweitzer D., Incident Response, Computer Forensics Toolkit, Wiley, ISBN: 0-7645-2636-7

National Institute of Standards and Technology (NIST)

http://seclists.org/

Cranor L. F., 2008 , A framework for reasoning about the human in the loop. In Proceedings of the 1st Conference on Usability, Psychology, and Security, pages 1–15, Berkeley, CA, USA, USENIX Association.

http://www.comptechdoc.org/independent/security/policies/incident-response-plan.html

CREST Incident Response Guide, 2013, https://www.crest-approved.org/wp-content/uploads/2014/11/CSIR-Procurement-Guide.pdf

https://ico.org.uk/for-organisations/report-a-breach/personal-data-breach/

https://ico.org.uk/for-organisations/the-guide-to-nis/what-is-nis/